

# INFORME EJECUTIVO — EVALUACIÓN DE VULNERABILIDADES Y PRUEBAS DE PENETRACIÓN

Cliente: FleetSec S.A.S. · Estado: Remediado / En Cumplimiento

|                                  |                              |                                        |                                 |
|----------------------------------|------------------------------|----------------------------------------|---------------------------------|
| RIESGO INICIAL<br><b>CRÍTICO</b> | RIESGO ACTUAL<br><b>BAJO</b> | HALLAZGOS CORREGIDOS<br><b>10 / 10</b> | CUMPLIMIENTO<br><b>LEY 1581</b> |
|----------------------------------|------------------------------|----------------------------------------|---------------------------------|

## PANORAMA GENERAL

FleetSec S.A.S. administra información de ubicación y telemetría de más de 60 000 vehículos, un tipo de dato personal protegido por la Ley 1581 de 2012, en un momento en que la empresa avanza hacia la certificación ISO/IEC 27001. La evaluación ofensiva realizada sobre la aplicación clasificó el riesgo inicial como crítico: un atacante externo, sin credenciales válidas, podía tomar control total de la base de datos, suplantar cualquier usuario incluyendo administradores y extraer sin restricción la información sensible de la flota.

## TOP 3 HALLAZGOS CRÍTICOS

| Hallazgo                                             | Riesgo         | Consecuencia si no se corrige                                                     |
|------------------------------------------------------|----------------|-----------------------------------------------------------------------------------|
| Credenciales de acceso expuestas en el código fuente | <b>Crítico</b> | Acceso directo a la infraestructura interna sin necesidad de robar contraseñas    |
| Inyección SQL en el inicio de sesión                 | <b>Crítico</b> | Evasión total de la autenticación y extracción de los datos de todos los usuarios |
| Falsificación de tokens de sesión                    | <b>Crítico</b> | Suplantación de cualquier usuario, incluidos los administradores, sin contraseña  |

## ESTADO DE LA SUPERFICIE AUDITADA

| Endpoint auditado            | Autenticación | Estado previo     | Estado actual |
|------------------------------|---------------|-------------------|---------------|
| /api/login                   | Ninguna       | <b>Vulnerable</b> | <b>SEGURO</b> |
| /api/proxy                   | Bearer JWT    | <b>Vulnerable</b> | <b>SEGURO</b> |
| /api/users/:id               | Bearer JWT    | <b>Vulnerable</b> | <b>SEGURO</b> |
| Repositorio de código fuente | No aplica     | <b>Vulnerable</b> | <b>SEGURO</b> |

## ACCIÓN INMEDIATA RECOMENDADA

Se ejecutó un plan de choque centrado en la reingeniería del código.

- **Gestión Segura de Claves y Accesos:** Se eliminaron de forma permanente las contraseñas e llaves maestras que estaban expuestas internamente en el sistema. Ahora las credenciales se administran mediante un gestor de secretos de alta seguridad en la nube y se auditó que no quedara ningún rastro en el historial del proyecto.
- **Protección de Datos Personales y Cumplimiento de la Ley 1581:** Para evitar sanciones regulatorias y proteger la privacidad de los clientes, se implementó un filtro automático que enmascara la información sensible (como cédulas y correos electrónicos) en los registros del sistema, garantizando que nadie pueda visualizarlos sin autorización.
- **Refuerzo de los Controles de Acceso y Blindaje del Sistema:** Se cerraron las brechas de entrada a las bases de datos y a la plataforma. Ahora el sistema valida la identidad de cada usuario mediante firmas digitales seguras, bloquea intentos de suplantación de roles administrativos, limita los intentos masivos de acceso sospechoso y restringe el tráfico hacia conexiones no autorizadas.
- **Verificación de Seguridad Efectiva (Pruebas Duales):** Se confirmó que las correcciones funcionan sin interrumpir la operación diaria. Cada medida fue sometida a pruebas reales: se verificó que el sistema bloquee y rechace con éxito cualquier intento de ataque, mientras permite el uso normal y fluido de los usuarios autorizados.